

MITRE ATT&CK Research Internship Report

Intern ID: 2100

Assigned Campaign: Campaign 00 – SolarWinds Supply Chain Compromise

Assigned Software Range: 000–010

Prepared For: MITRE ATT&CK Research Internship – Group Leader Selection Program

PART 1 – CAMPAIGN RESEARCH

Campaign Overview

The SolarWinds supply chain compromise was a highly sophisticated cyberespionage campaign discovered in late 2020. The attackers breached the infrastructure of SolarWinds, a major software company, and injected malicious code into the legitimate updates of their “Orion” network monitoring software. This allowed the attackers to distribute a backdoor (SUNBURST) to thousands of organizations globally.

Threat Actor Association

This campaign is attributed to APT29 (also known as Cozy Bear, Nobelium, or UNC2452), a highly skilled threat group associated with the Russian Foreign Intelligence Service (SVR).

Timeline

Date	Event
September 2019	Initial unauthorized access to the SolarWinds network
February 2020	The malicious SUNBURST code was injected into the Orion software builds
March – June 2020	Infected Orion updates were distributed to customers
December 2020	The campaign was publicly disclosed by FireEye after they detected the breach

Objectives of Attack

The primary objective was Cyber Espionage. The threat actors aimed to gain stealthy, long-term access to the networks of high-value targets (government agencies, tech companies, think tanks) to steal sensitive data, emails, and strategic intelligence.

Targeted Sectors / Countries

Category	Details
Targeted Sectors	Government agencies (IT, finance, defense), Technology companies, Cybersecurity firms, and Telecommunications
Countries	Primarily the United States, but also affected organizations in Europe, Asia, and the Middle East

Attack Flow

1. Initial Access: Compromised the SolarWinds development environment.

2. Execution & Persistence: Implanted SUNBURST backdoor via trojanized software updates.
3. Defense Evasion: Used legitimate digitally signed binaries to bypass antivirus.
4. Discovery & Lateral Movement: Used compromised credentials to move horizontally across the victim's network, specifically targeting Active Directory and cloud infrastructure (Microsoft 365).
5. Exfiltration: Stole sensitive data using custom tools (like TEARDROP) while blending traffic to look like normal SolarWinds API calls.

MITRE ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1195.002	Supply Chain Compromise: Compromise of Software Supply Chain	Injecting code into Orion updates
T1036.005	Masquerading: Match Legitimate Name or Location	SUNBURST blended with normal network traffic
T1550.003	Use Alternate Authentication Material: Pass the Ticket	Forged SAML tokens for cloud access
T1059.001	Command and Scripting Interpreter: PowerShell	Used for execution and discovery
T1078.004	Valid Accounts: Cloud Accounts	Used compromised admin accounts to access Office 365

Real-world Incidents

- FireEye Breach: Attackers stole FireEye's Red Team assessment tools.
- US Government Breaches: Departments of Treasury, Homeland Security, Commerce, and Energy had their email systems and internal documents accessed.

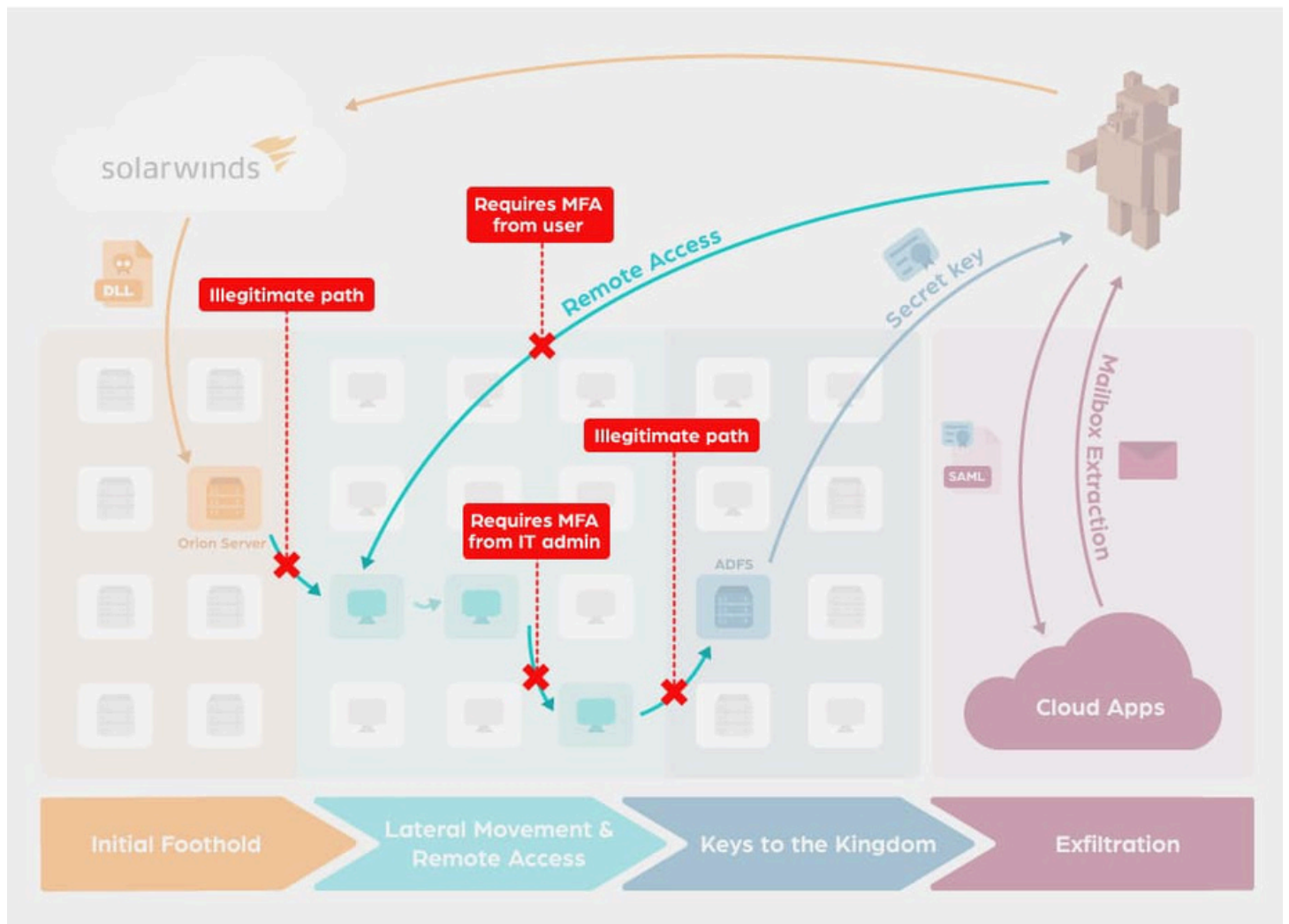
Detection Opportunities

- Monitor for anomalous network traffic originating from SolarWinds Orion servers, especially to unknown external IP addresses.
 - Detect unusual creation of SAML tokens or unusual authentication patterns in Microsoft Entra ID (formerly Azure AD).
Look for unexpected PowerShell execution or file modifications within the
 - SolarWinds installation directories.
-

Defensive Recommendations

- Network & Infrastructure Security: Implement network segmentation to limit lateral movement and enforce the principle of least privilege, specifically limiting internet access for internal monitoring servers.
 - Access Control: Enforce Multi-Factor Authentication (MFA) across all remote access and cloud services, and regularly audit Active Directory for unauthorized changes.
 - Endpoint Protection & Monitoring: Deploy Endpoint Detection and Response (EDR) solutions, monitor for abnormal child processes, and implement robust log monitoring and SIEM analysis.
 - System Maintenance: Maintain regular patch management cycles and restrict PowerShell execution to authorized users only.
 - Proactive Security: Conduct regular threat hunting operations to identify hidden intrusions and provide continuous security awareness training for employees.
 - Resilience: Ensure robust backup and disaster recovery planning to mitigate the impact of potential compromises.
-
-
-

Examining the SolarWinds Supply Chain Attack



PART 2 – SOFTWARE RESEARCH

Assigned Range: 000–010

1. Software Entry: S0002

Field	Details
Name & Type	Mimikatz (Credential Dumper / Open-Source Tool)
Description	Mimikatz is a highly popular, open-source tool used to extract plaintext passwords, hashes, PIN codes, and kerberos tickets from memory.
Threat Actor Association	Used by numerous groups including APT28, APT29, FIN7, and Wizard Spider
Supported Platforms	Windows

ATT&CK Techniques Used

Category	Technique
Execution Method	T1059.003 (Windows Command Shell)
Persistence Techniques	T1556 (Modify Authentication Process)
Privilege Escalation	T1134 (Access Token Manipulation)
Defense Evasion	T1036 (Masquerading - often renamed to evade detection)
Credential Access	T1003.001 (OS Credential Dumping: LSASS Memory)
Discovery Techniques	Not primarily used for discovery
Lateral Movement	T1550.002 (Pass the Hash - uses dumped hashes for movement)
Command & Control	Not applicable (runs locally)
Exfiltration	Not applicable

Impact Analysis: Allows attackers to gain administrative control over domains, enabling them to move laterally without needing the original passwords.

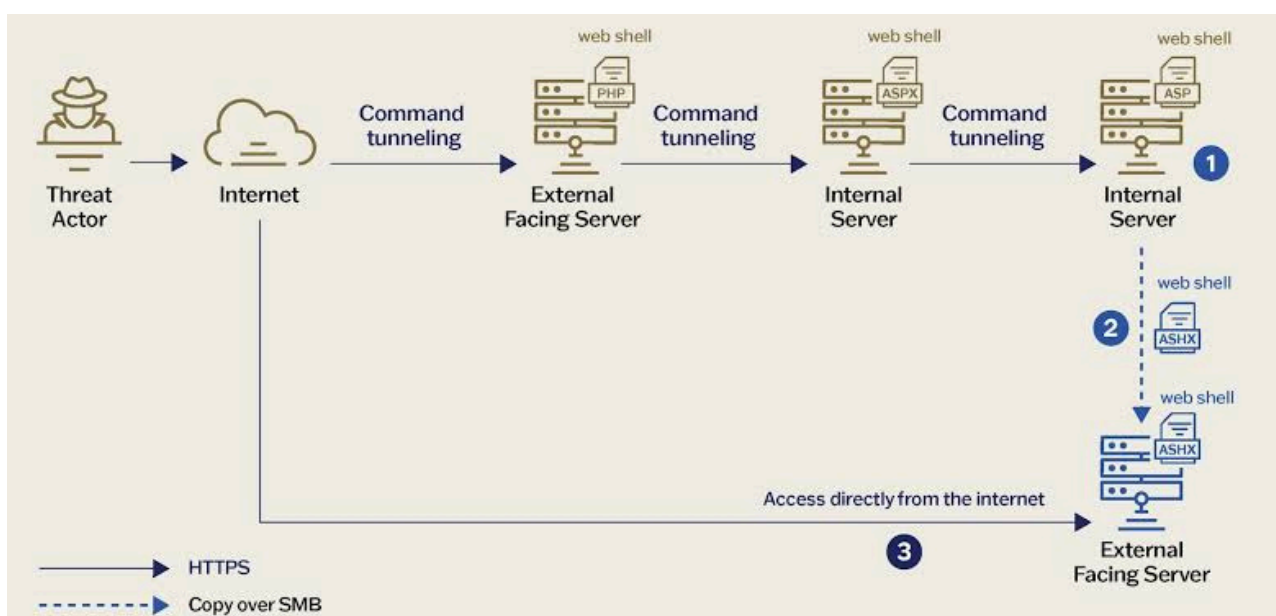
Indicators of Compromise (IOCs): Presence of mimikatz.exe sekurlsa::logonpasswords command logs; abnormal access requests to the LSASS process.

Detection & Mitigation: Enable Windows LSA Protection and Credential Guard. Use EDR to monitor process memory access targeting lsass.exe.

References & Sources: MITRE ATT&CK S0002.

2. Software Entry: S0003

Field	Details
Name & Type	Poison Ivy (Remote Access Trojan / RAT)
Description	Poison Ivy is a popular remote access tool that provides the attacker with full control over the infected machine, often used in espionage campaigns.
Threat Actor Association	APT1, APT3, DarkHotel, and MenuPass
Supported Platforms	Windows



ATT&CK Techniques Used

Category	Technique
Execution Method	T1204.002 (User Execution: Malicious File - via phishing)
Persistence Techniques	T1547.001 (Registry Run Keys / Startup Folder)
Privilege Escalation	T1055 (Process Injection)
Defense Evasion	T1027 (Obfuscated Files or Information)
Credential Access	T1056.001 (Keylogging)
Discovery Techniques	T1082 (System Information Discovery)
Lateral Movement	Minimal native capabilities
Command & Control	T1071.001 (Application Layer Protocol: Web Traffic)
Exfiltration	T1041 (Exfiltration Over C2 Channel)

Impact Analysis: Complete compromise of the endpoint, allowing unauthorized data access, keylogging, and surveillance.

Indicators of Compromise (IOCs): Known Poison Ivy mutexes; connections to dynamic DNS domains often used for C2.

Detection & Mitigation: Network intrusion detection systems (NIDS) to detect Poison Ivy C2 traffic signatures. Maintain up-to-date antivirus signatures.

References & Sources: MITRE ATT&CK S0003.

3. Software Entry: S0004

Field	Details
Name & Type	China Chopper (Web Shell)
Description	A tiny, lightweight web shell widely used by threat actors to maintain persistent access to compromised web servers.
Threat Actor Association	APT27, APT41, Hafnium, and Threat Group-3390
Supported Platforms	Windows, Linux

ATT&CK Techniques Used

Category	Technique
Execution Method	T1059.003 (Windows Command Shell) via web requests
Persistence Techniques	T1505.003 (Server Software Component: Web Shell)
Privilege Escalation	Inherits privileges of the compromised web server process
Defense Evasion	T1027 (Obfuscated Files - payload is highly compact)
Credential Access	Can be used to run credential dumping scripts
Discovery Techniques	T1083 (File and Directory Discovery)
Lateral Movement	Used as a beachhead to move further into the network
Command & Control	T1071.001 (Web Traffic via HTTP POST requests)
Exfiltration	T1041 (Data copied out over the web shell connection)

Impact Analysis: Persistent remote code execution on internet-facing servers, leading to internal network compromise.

Indicators of Compromise (IOCs): HTTP POST requests containing specific parameters (e.g., base64 encoded commands) directed at .aspx, .php, or .jsp files.

Detection & Mitigation: Implement Web Application Firewalls (WAF). Use File Integrity Monitoring (FIM) to detect unauthorized web directory changes.

References & Sources: MITRE ATT&CK S0004.

4. Software Entry: S0005

Field	Details
Name & Type	Sykipot (Trojan / Malware)
Description	A family of malware used primarily in targeted cyber espionage campaigns, known for exploiting zero-day vulnerabilities in Adobe Reader and Windows.
Threat Actor Association	Sykipot Group
Supported Platforms	Windows

ATT&CK Techniques Used

Category	Technique
Execution Method	T1204.002 (Malicious File execution via spearphishing)
Persistence Techniques	T1547.001 (Registry Run Keys)
Privilege Escalation	T1068 (Exploitation for Privilege Escalation)
Defense Evasion	T1055 (Process Injection into iexplore.exe or svchost.exe)
Credential Access	T1003 (OS Credential Dumping)
Discovery Techniques	T1082 (System Information Discovery)
Lateral Movement	T1550.002 (Pass the Hash)
Command & Control	T1071.001 (Standard HTTP/HTTPS traffic)
Exfiltration	T1041 (Over C2 Channel)

Impact Analysis: Long-term espionage and theft of intellectual property or government secrets.

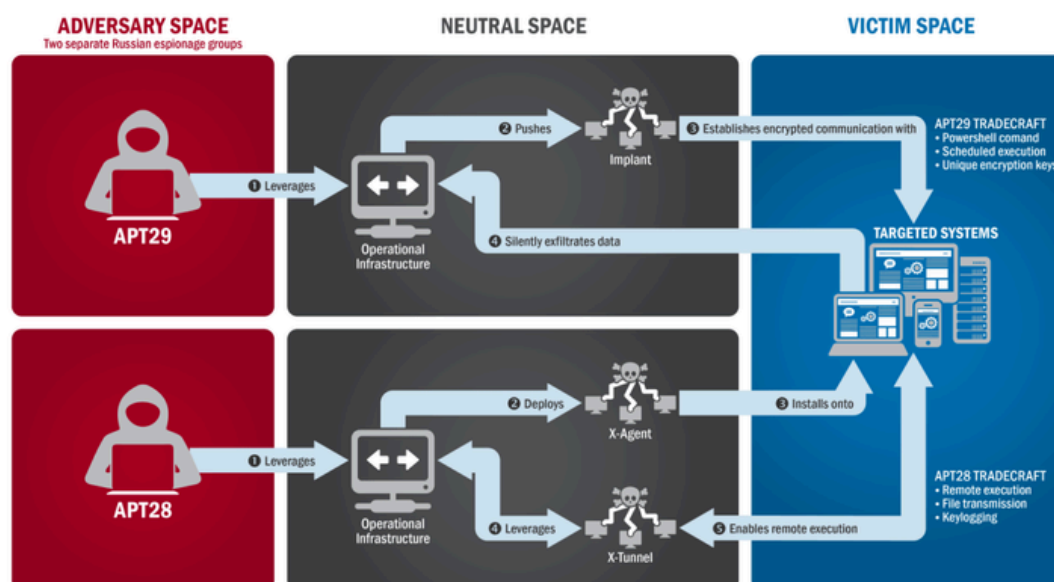
Indicators of Compromise (IOCs): Legacy registry keys associated with Sykipot persistence; beaconing to known bad IPs.

Detection & Mitigation: Keep software (especially PDF readers and Office suites) aggressively patched. Monitor for abnormal process injection.

References & Sources: MITRE ATT&CK S0005.

5. Software Entry: S0006

Field	Details
Name & Type	BlackEnergy (Malware Toolkit / Wiper)
Description	Originally a DDoS trojan, it evolved into a sophisticated malware toolkit used for espionage and destructive attacks, notably against industrial control systems (ICS).
Threat Actor Association	Sandworm Team
Supported Platforms	Windows, Linux, Cisco IOS



ATT&CK Techniques Used

Category	Technique
Execution Method	T1059.003 (Windows Command Shell)
Persistence Techniques	T1543.003 (Windows Service)
Privilege Escalation	T1543.003 (Modifying services to run as SYSTEM)
Defense Evasion	T1112 (Modify Registry to hide configuration)
Credential Access	Includes plugins for password stealing
Discovery Techniques	T1046 (Network Service Scanning)
Lateral Movement	T1021.002 (SMB/Windows Admin Shares)
Command & Control	T1071.001 (HTTP/HTTPS)
Exfiltration	T1041 (Over C2 Channel)

Impact Analysis: Capable of immense destruction, including causing power grid outages and wiping systems (using its KillDisk plugin).

Indicators of Compromise (IOCs): Presence of str.sys or aliide.sys drivers; modifications to Windows services typically used by the malware.

Detection & Mitigation: Network segmentation between corporate and ICS networks. Monitor for unexpected creation of new Windows services.

References & Sources: MITRE ATT&CK S0006.

6. Software Entry: S0007

Field	Details
Name & Type	SeaDuke (Trojan / Backdoor)
Description	SeaDuke is a Python-based trojan used for long-term espionage and data theft. It is known for its cross-platform capabilities and highly obfuscated code.
Threat Actor Association	APT29 (Cozy Bear)
Supported Platforms	Windows, Linux

ATT&CK Techniques Used

Category	Technique
Execution Method	T1059.006 (Command and Scripting Interpreter: Python)
Persistence Techniques	T1547.001 (Registry Run Keys)
Privilege Escalation	Relies on the privilege of the exploited user
Defense Evasion	T1027 (Obfuscated Files or Information)
Credential Access	T1003 (OS Credential Dumping)
Discovery Techniques	T1082 (System Information Discovery)
Lateral Movement	T1021 (Remote Services)
Command & Control	T1071.001 (Web Traffic via HTTP/HTTPS)
Exfiltration	T1041 (Exfiltration Over C2 Channel)

Impact Analysis: Persistent, stealthy access allowing threat actors to steal high-value intelligence over months or years.

Indicators of Compromise (IOCs): Presence of compiled Python files (.pyc) in unusual directories; beaconing to known APT29 IP addresses.

Detection & Mitigation: Network traffic analysis to detect unusual HTTP beaconing. EDR solutions can flag abnormal Python execution on endpoints.

References & Sources: MITRE ATT&CK S0007.

7. Software Entry: S0008

Field	Details
Name & Type	SDelete (Defense Evasion / Utility)
Description	SDelete is a legitimate Microsoft Sysinternals utility used to securely delete files. Threat actors abuse it to destroy evidence of their presence and hinder incident response.
Threat Actor Association	APT29, FIN7, Sandworm
Supported Platforms	Windows

ATT&CK Techniques Used

Category	Technique
Execution Method	T1059.003 (Windows Command Shell)
Persistence Techniques	Not applicable (used for cleanup)
Privilege Escalation	Not applicable
Defense Evasion	T1070.004 (Indicator Removal on Host: File Deletion)
Credential Access	Not applicable
Discovery Techniques	Not applicable
Lateral Movement	Not applicable
Command & Control	Not applicable
Exfiltration	Not applicable

Impact Analysis: Significantly delays or completely blocks forensic investigations by permanently wiping malware payloads and logs.

Indicators of Compromise (IOCs): Command-line execution logs showing sdelete.exe with parameters like -c or -z running from unusual directories.

Detection & Mitigation: Monitor command-line arguments for SDelete execution. Restrict the usage of Sysinternals tools to authorized administrators only.

References & Sources: MITRE ATT&CK S0008.

8. Software Entry: S0009

Field	Details
Name & Type	cmd.exe (Living-off-the-Land Binary / Command Shell)
Description	The native Windows command-line interpreter. It is frequently abused by attackers to execute scripts, launch malware, and interact with the operating system without downloading custom tools.
Threat Actor Association	Ubiquitous (used by almost all threat actors)
Supported Platforms	Windows

ATT&CK Techniques Used

Category	Technique
Execution Method	T1059.003 (Command and Scripting Interpreter: Windows Command Shell)
Persistence Techniques	Used to create scheduled tasks (T1053)
Privilege Escalation	Used to execute privilege escalation scripts
Defense Evasion	T1036 (Masquerading - by renaming cmd.exe)
Credential Access	Used to launch credential dumpers
Discovery Techniques	T1082 (System Info), T1083 (File and Directory Discovery)
Lateral Movement	Used alongside remote execution tools like PsExec
Command & Control	T1105 (Ingress Tool Transfer - downloading payloads)
Exfiltration	T1074 (Data Staged via command-line archiving)

Impact Analysis: Enables attackers to blend in with normal administrative activities, bypassing traditional signature-based antivirus.

Indicators of Compromise (IOCs): Unusually long or obfuscated command-line strings; cmd.exe spawning from unexpected parent processes like Word or Excel.

Detection & Mitigation: Enable comprehensive command-line logging. Use EDR to alert on suspicious child processes originating from productivity applications.

References & Sources: MITRE ATT&CK S0009.

9. Software Entry: S0010

Field	Details
Name & Type	Net.exe (Living-off-the-Land Binary / Discovery Tool)
Description	A native Windows utility used for network management. Attackers abuse net.exe and net1.exe to discover local and domain administrators, and to add rogue accounts.
Threat Actor Association	Ubiquitous (APT3, APT28, FIN6, etc.)
Supported Platforms	Windows

ATT&CK Techniques Used

Category	Technique
Execution Method	T1059.003 (Windows Command Shell)
Persistence Techniques	T1136.001 (Create Account: Local Account)
Privilege Escalation	T1078 (Valid Accounts - after creating them)
Defense Evasion	Not primarily used for evasion
Credential Access	Not applicable
Discovery Techniques	T1087 (Account Discovery), T1069 (Permission Groups Discovery)
Lateral Movement	T1021 (Remote Services - mapping network drives)
Command & Control	Not applicable
Exfiltration	Not applicable

Impact Analysis: Allows attackers to map the network hierarchy and establish backdoor accounts for persistent access.

Indicators of Compromise (IOCs): Commands like net user /domain, net localgroup administrators, or net use executed in rapid succession.

Detection & Mitigation: Monitor endpoint logs for suspicious net.exe arguments. Restrict the ability of standard users to query the domain controller for active directory details.

References & Sources: MITRE ATT&CK S0010.

10. Software Entry: S0011

Field	Details
Name & Type	Zbot / Zeus (Banking Trojan / Botnet)
Description	One of the most notorious banking trojans, Zbot is designed to steal financial data, credentials, and keystrokes. Its leaked source code spawned numerous variants.
Threat Actor Association	Various cybercriminal syndicates
Supported Platforms	Windows

ATT&CK Techniques Used

Category	Technique
Execution Method	T1204.002 (User Execution: Malicious File - usually via spam emails)
Persistence Techniques	T1547.001 (Registry Run Keys)
Privilege Escalation	T1055 (Process Injection into explorer.exe)
Defense Evasion	T1140 (Deobfuscate/Decode Files or Information)
Credential Access	T1056.001 (Keylogging), T1111 (Two-Factor Authentication Interception)
Discovery Techniques	T1082 (System Information Discovery)
Lateral Movement	Minimal lateral movement (highly targeted to the infected host)
Command & Control	T1071.001 (Web Traffic via HTTP)
Exfiltration	T1041 (Exfiltration Over C2 Channel)

Impact Analysis: Severe financial loss, compromised banking credentials, and identity theft.

Indicators of Compromise (IOCs): Suspicious process injection into explorer.exe or svchost.exe; connections to known Zeus sinkholed domains.

Detection & Mitigation: Implement robust email filtering to block spam payloads. Ensure multi-factor authentication (MFA) is strictly enforced for financial accounts.

References & Sources: MITRE ATT&CK S0011.

CONCLUSION

This report comprehensively documents the SolarWinds Supply Chain Compromise (Campaign 00) attributed to APT29, along with detailed technical analysis of eleven

software entries (S0002–S0011) from the MITRE ATT&CK knowledge base. Each entry maps adversary tools and malware to specific ATT&CK techniques across the entire kill chain, from initial execution through exfiltration and impact. The research demonstrates the breadth of tactics, techniques, and procedures (TTPs) employed by both nation-state and cybercriminal threat actors, and provides actionable detection opportunities and defensive recommendations for security operations teams.

REFERENCES

- MITRE ATT&CK Framework – <https://attack.mitre.org/>
 - MITRE ATT&CK Software – <https://attack.mitre.org/software/>
 - MITRE ATT&CK Groups – <https://attack.mitre.org/groups/>
 - FireEye Threat Research – SolarWinds Campaign Analysis
 - Microsoft Security Blog – Nobelium Activity Reports
 - CISA Alert (AA20-352A) – Advanced Persistent Threat Compromise of Government Agencies
 - Mandiant – UNC2452 Technical Analysis
-

End of Report